

Дигитална форензика

8. Истрага на упад во системи

◦ Методологија

- * Истрага за упад е специјализирана подгрупа на дигитална форензичка истрага
 - » неовластен пристап
 - » нарушувањата на безбедноста
 - автоматски малициозен софтвер што собира кориснички имиња, лозинки, информации за платежни картички, лични информации...
 - откако натрапниците ќе добијат неовластен до мрежа, тие користат компоненти на системот со кои ја отежнуваат истрагата.
- * Припаѓа во категоријата на “CyberCrime”
- * Целта на секоја фаза е:
- * Подготовка - како да се одговори на инцидент?
 - » подготовка од организациска, техничка и индивидуална перспектива
- * Откривање и анализа - што се случило?
 - » откривање на инцидент, анализа на податоците и нивна употреба
- * Задржување, искоренување и обновување – како да се поврати угледот?
 - » санација на инцидентот и враќање на организацијата каде се случил инцидентот во подоверлива состојба (more trusted state)
- * Активност по инцидентот – што е научено?
 - » организацијата презема чекори за идентификување, спроведување на “научените лекции” од настанот, ги извршува сите правни активности
- * Примена на научен метод
 - » избор на едноставен, флексибилен пристап
 - » Научен пристап применлив на еден компјутер или цел комплексен систем
 - Набљудување->Хипотеза->Предвидување-> Експериментирање/Тестирање -> Заклучок.
- * Пред/за време/после инцидентот?
- * Две главни задачи во истрагата за упад на системи се:
 - » проценка на опсег (Scope Assessment) - се одредува бројот на компјутери во нападот и се повторува постапката.
 - » реконструкција на криминалот (Crime Reconstruction)

◦ Планирање

- 🌸 за истрага за упад вклучува:
 - ➡ развој на политики и процедури
 - ➡ инфраструктура за најавување
 - ➡ конфигурирање на компјутерски системи како извори на докази
 - ➡ соодветно опремен и обучен тим за одговор
 - ➡ изведување на периодични вежби за одговор на инциденти
- 🌸 Цел: обезбедување целосна подготвеност
- 🌸 Скоро секоја мрежа доживува нарушување на безбедноста на информациите.
 - ➡ Планирањето е клучно за навремен, темелен одговор на инцидент.
 - ➡ Поедноставно е да се испита инцидент кога:
 - ◇ проблемот ќе се открие наскоро по инцидентот
 - ◇ кога изворите на докази се зачувани правилно

- ◇ кога има логови што можат да се користат за реконструкција на настаните поврзани со упадот

✿ Финансиски импликации

- ➡ Трошоците се пониски за организациите кои биле подготвени за инциденти
- ➡ Препорака: да се дизајнираат мрежи и да се опреми персонал на таков начин што организацијата
 - ◇ може да открие и да се справи со безбедносните настани што е можно побрзо и поефикасно,
 - ◇ Ќе ги минимизираат загубите поврзани со застојот и кражбата на податоците.

✿ Еден од најважните аспекти на подготовката за нарушување на безбедноста е:

- ➡ идентификување, документирање на средствата за информации во една организација и локацијата на чувствителни, вредни податоци

✿ Без разбирање на средствата и ризиците не може да утврди кои безбедносни нарушувања треба да имаат најголем приоритет

✿ Ефективната истрага за упад зависи од добрите практики за управување со ризик.

- ➡ Без план за управување со ризик и проценка на средствата, управувањето со инциденти е премногу тешко и скапо.
- ➡ Треба да се воспостават безбедносни мерки за да се заштитат и следат податоците и да се осигура дека само соодветните страни имаат пристап до нив.

✿ Чекори за поефикасно спроведување на истрагите за упад се:

☆ Ресурси (средства)

- ➡ За да се заштити имотот на организација и да испита каков било безбедносен настан, мора да се знае кои се средствата, каде се и во каква состојба треба да бидат.
- ➡ Треба да се чува документација за средствата.
- ➡ Ефикасното управување со средствата зависи од:
 - ◇ Топологија на мрежата
 - ◇ Физичка локација на сите уреди
 - ◇ Верзии и статус на оперативниот систем
 - ◇ Локација на клучните податоци

☆ Правила и процедури

- ➡ неопходни за тоа како организацијата ќе се справи со безбедносен настан кога ќе се случи.
- » Примери на корисни правила и процедури:
 - ✿ **Клучен персонал**
 - ◇ сите лица кои ќе учествуваат во истрагата за упад и нивните улоги.
 - ✿ **Дефинирање на инциденти и праг/граница на инцидентите**
 - ◇ кои активности се сметаат за безбедносен инцидент и кога ќе се објави дека се случил.
 - ✿ **Постапки во случај на ескалација**
 - ◇ Услови на ескалација
 - ✿ **Упатства за затворање**
 - ◇ Условите под кои инцидентот се смета за затворен
 - ✿ **Постапки за управување со докази**
 - ◇ Како доказите ќе бидат управувани, пренесени, чувани и на друг начин заштитени.
 - ✿ **Упатства за ограничување и санирање**
 - ◇ Условите под кои една организација ќе се обиде да спречи и санира инцидент.
 - ✿ **Упатства за објавување на информации**
 - ◇ Кој треба да биде известен за време на истрагата, а кој не.
 - ✿ **Правила за комуникација**
 - ◇ Како истражниот тим ќе комуницира без да го предупредува напаѓачот за активноста.
 - ✿ **Постапки за енкрипција/декрипција**
 - ◇ Што е криптирано и како податоците може да се декриптираат доколку е потребно.

☆ Подготовка на ресурси

- ➡ Компјутерските системи (ресурсите) не се поставени на таков начин што нивната конфигурација ќе биде “пријателска” за форензичката анализа

☆ **Задржување (log retention)**

- » Политики за задржување на податоците што наложуваат отстранување на информации засновани на староста и видот на информациите.
- ➡ Повеќе фактори:
 - ◇ трошоци за складирање на податоци на неодредено време
 - ◇ трошоци за пристап до тие податоци откако ќе бидат зачувани
 - ◇ Законски регулативи

☆ **Мрежна архитектура**

- ➡ Нејзината комплексност го отежнува процесот на истрагата
- ◇ Колку повеќе точки на влез/излез се додаваат во мрежата на организацијата, толку потешко е да се следат активностите на натапаниците.
- ◇ Ако мрежите се конструирани имајќи ја предвид безбедноста, тогаш се олеснува истрагата за упад.
- ◇ Намалување на излезни точки
- ◇ Мониторинг на сите влез/излез точки
- ◇ Оневозможување енкрипција на влез/излез без употреба на проху сервер
- ◇ Чување на сите логови на уреди на сервер

🌸 **Стандардна ИТ практика.**

- ➡ Полесно е да се управува кога организациите знаат каде се сите нивни системи, како се поврзани системите и нивниот тековен статус.
- » Организацијата треба редовно ги документира овие податоци.

🌸 **Сè што би требало да знае дигитален истражувач е како да ги добие податоците.**

🌸 **Во однос на форензичката подготовка, една организација мора да ги идентификува механизмите за пренос и складирање на важни податоци.**

🌸 **Надвор од протокот на податоци, треба да се воспостават политики за регулирање не само за тоа кои податоци се чуваат, туку и колку долго се чуваат и како треба да се отстрануваат.**

🌸 **Предлози за подготовка на системите за форензичка анализа**

- ➡ Активирање на системски и безбедносни операции за најавување
- ➡ Активирање на “file system journals”
- ➡ Чување историја на активности на авторизирани корисници
- ➡ Чување на swap/page file за потреби на истрагата
- ➡ Логирање на firewall активности
- ➡ Подесување на опции кај антивирусни програми
- ➡ Ограничување на авторизирани операции на минимум

◦ **Иницијална опсервација**

- ◆ Безбедносните инциденти можат да започнат на различни начини.
- ◆ Начинот на првичното откривање на инцидентот ќе ги утврди постапите на почетокот на истрагата.
- ◆ Некои од почестите почетни набудувања се:
 - » Antivirus
 - » IDS
 - » “Blacklist” правила
 - » Информации надвор од инцидентот

◦ **Заклучок**

- ➔ Истрага на упад во системите
 - » Многу динамичен процес

- » Бара доста искуство при управување со инцидентни настани
- » Познавање на техники и вештини посебно ако напаѓачот е активен
- » Користење на научен пристап за подобри резултати

➔ Успешноста на овој вид истрага во голема мера зависи од тоа дали има механизам за следење на истражните и форензичките подзадачи.